



PROOFPOINT CYBERSECURITY ACADEMY · CERTIFIED AI AGENT SECURITY SPECIALIST 2026 · SESSION 2

The Agentic Workspace: Visibility and Posture

Six everyday ways AI use slips outside security's view, and the technical and people controls that bring each one back under governance.

PRESENTERS

Patrick Pushor (Director, Solution Architecture) · Tim Choi (GVP, Product Strategy and GTM, AI Security)

CONTENTS

- 01 At a glance
- 02 Tier of service
- 03 Local models
- 04 Data sources via MCP
- 05 SaaS connectors
- 06 Public models
- 07 Prompt injection

QUICK RECALL

Every scenario follows the same fix: one managed path for AI traffic, least privilege on every connector, and logs that tie each prompt and tool call back to a person.

Six scenarios, one question: can you see it?

Session 1 argued that you can't secure what you can't see. Session 2 makes that concrete with six situations that show up in almost every enterprise, and walks each one through the same three lenses: what can go wrong, which technical controls address it, and which people and process controls back those up.

SCENARIO	WHERE VISIBILITY BREAKS	FIRST CONTROL TO REACH FOR
Tier of service	Free and personal plans sit outside company contracts and logging	Corporate SSO on enterprise tiers, block consumer tiers
Local models	AI runs on the laptop, outside network and cloud controls	Application allow-listing through EDR
Data sources via MCP	AI gets read and write access to core systems	Least-privilege MCP identities behind a gateway
SaaS connectors	Users grant broad OAuth access in a few clicks	Admin-approved consent only
Public models	Sensitive data leaves in a prompt, instantly	Inline DLP on all GenAI-bound traffic
Prompt injection	Hidden instructions steer the AI with the user's own privileges	Injection detection plus tool-call allowlists

02 • SCENARIO 1

Free, paid and enterprise tiers

When staff use different tiers of the same GenAI platform, the company loses consistency in how its data is handled, retained and contractually protected. Free and consumer tiers often allow the provider to keep prompts or train on them, and they lack SSO enforcement, audit logging, data residency guarantees and indemnification. Even a paid individual subscription gives the company no central visibility, policy control or offboarding control, so data ends up processed under terms nobody reviewed.

Risks

Data retained or used for training under consumer terms; no audit trail for compliance or incident response; no SSO, MFA or conditional access; no contractual protection or breach notification; accounts that stay active after offboarding; data processed in unapproved jurisdictions.

Technical controls

Send outbound GenAI traffic through a managed control point that can spot and enforce which tier is in use, require corporate SSO for approved platforms and block consumer tiers, apply inline DLP, log prompts and outputs with user attribution, and allow-list sanctioned services while denying unknown providers.

People & process

Publish an AI acceptable use policy naming approved tiers, buy enterprise plans through IT review instead of personal credit cards, train staff on retention differences, have Legal review provider terms before approval, add GenAI to offboarding checklists, and run an AI governance committee (Security, Legal, IT, Business) that reassesses providers.

03 • SCENARIO 2

Local models on work devices

Employees can download open-source or packaged LLMs and run them on corporate laptops through local runtimes or desktop AI tools, with no central approval. Because everything happens on the device, it sits outside network visibility and cloud governance, and tools sold as offline or private feel low risk, so they skip procurement. The problem isn't the model itself; it's the lack of visibility, control and consistent policy at the endpoint.

Risks

Company data pulled into local vector stores with no audit logging; tampered or malicious model weights and plugins; runtimes exposing unexpected APIs or open ports; no DLP or content moderation; heavy CPU and GPU load; outputs trusted without validation.

Technical controls

Allow-list applications through EDR or OS controls to stop unauthorized AI runtimes, watch endpoints for model binaries and inference engines, restrict model downloads from common repositories with DNS/SNI and web gateway rules, lock down local API listeners with the host firewall, and run endpoint DLP on vector stores and model caches.

People & process

Back the technical controls with policy and add centralized endpoint telemetry so AI-related processes and resource use stay visible over time.

04 • SCENARIO 3

Connecting company data sources through MCP

Connecting internal data to a third-party GenAI system over MCP gives the AI more than read access. It can also write: update records, open tickets, edit documents and trigger workflows, which turns an assistant into an operator inside core business systems. MCP integrations are usually token-based and often inherit the full privileges of a service account, sometimes with no fine-grained authorization or transaction monitoring.

Risks

Service accounts with broad read access across repositories; the model correlating sensitive data across systems; prompt injection widening access beyond scope; unapproved writes; stolen tokens or API keys giving direct backend access; no log tying an AI read or write to a human decision-maker.

Technical controls

Give each data source its own least-privilege MCP identity, put MCP behind a gateway that handles authentication, request signing, policy and rate limits, keep tokens short-lived, rotated and vault-backed with egress controls, enforce injection detection and tool-call allowlists, and keep immutable audit logs binding every call to a user, system, object and session.

People & process

Require a security architecture review before any connector goes live, map which repositories AI may touch, name a business and technical owner per integration, put write-capable actions under change management, include AI access in entitlement audits, and train developers on safe tool invocation.

05 • SCENARIO 4

Connecting SaaS apps to GenAI

GenAI platforms now ship native connectors for Google Drive, OneDrive, calendars, Slack and CRMs. They run on OAuth, end users can switch them on without IT, and they look like simple productivity features, yet one approval can open a large share of a user's SaaS data to the model with no central risk review.

Risks

OAuth scopes covering whole drives, mailboxes or chat histories; exposure that grows silently as new content is created; cross-platform aggregation of email, documents and chat; injection prompting the AI to summarize confidential content; tokens that survive role changes and offboarding; little visibility into which objects the AI touched.

Technical controls

Disable end-user OAuth consent and require admin-approved apps and scopes (Entra or Google Workspace), apply conditional access to connector authorization, detect and block unsanctioned GenAI apps, keep a token inventory with automatic revocation, and use DLP and egress controls with central logging.

People & process

Run a connector approval workflow with Security, IT and Legal, set a standard for acceptable scopes, assign a business owner to every connector, recertify connector permissions quarterly, ban self-authorized SaaS-to-AI connections in the AUP, and teach staff how far one OAuth consent reaches.

06 • SCENARIO 5

Sensitive data shared with public models

People paste proprietary or regulated information into public GenAI tools to summarize, analyze, draft or troubleshoot. Those models run on third-party infrastructure outside the company's control, and consumer tiers may keep or process data under different terms even when the vendor says it won't train on enterprise data. Because prompting feels like chatting, employees often don't realize they're handing confidential data to an outside processor, and it leaves in seconds with no classification or handling guarantees.

Risks

Regulated data (PII, PHI, PCI, financials) creating compliance violations; loss of IP, source code and strategy documents; retention or training under consumer terms; cross-border transfers; no proof of what was submitted during an investigation; reputational damage if the data resurfaces in model outputs.

Technical controls

Route all GenAI traffic through inline inspection with real-time DLP, classify content to block or redact regulated data, allow-list enterprise platforms and block public tiers at DNS/SNI and the endpoint, use browser or endpoint agents to stop sensitive copy and paste, log prompts and responses with attribution, and limit GenAI to compliant devices and managed identities.

People & process

Spell out prohibited data types in the AUP, make AI usage training mandatory with real leakage examples, fold GenAI into existing data handling standards, give staff an escalation path when unsure, add GenAI scenarios to awareness simulations and tabletops, and require Legal and Compliance sign-off on new public platforms.

07 • SCENARIO 6

Prompt injection causing data exfiltration

Prompt injection hides malicious instructions inside content the AI reads: a document, web page, email or knowledge base entry. The user may do nothing more than open or query it, and the AI follows the embedded instructions as part of its reasoning, revealing data or taking actions it shouldn't. The damage scales with what the AI is connected to, because the attack runs with the user's own legitimate privileges.

Risks

Retrieval of confidential documents, email and records within the user's scope; aggregation across connected sources; exfiltration through summaries, exports and downstream tool calls; unauthorized writes; human judgment bypassed because the target is the model's reasoning; attacks that are hard to spot inside legitimate content.

Technical controls

Detect injection and sanitize content before the model sees it, enforce tool-call allowlists with parameter validation, apply least privilege to every MCP and SaaS connector, require human approval for high-risk or bulk actions, log reasoning steps, tool calls and retrieved objects for anomaly detection, and filter egress with DLP.

People & process

Teach staff that AI answers can be manipulated even when content looks legitimate, require threat modeling for any AI system with tool or data access, review least privilege before enabling new connectors or write tools, add injection to red team and tabletop exercises, write an AI exfiltration playbook, and hold AI system owners accountable for monitoring and review.

The core challenge is that injected prompts can silently transform a trusted AI assistant into a data extraction mechanism operating with legitimate user privileges.

SESSION 2 • PROMPT INJECTION SCENARIO